

Mast?re 2 Cybers?curit? - Projet M2

SOC externalis? pour un r?seau d?audioproth?ses

Client : Daylight | Prestataire : Cyber Trust

PARTIE INDIVIDUELLE

Mahamadou DIACOUMBA

Exploitation SOC, playbooks, proc?dures et REX incidents

?l?ment	Contenu
R?le projet	Exploitation SOC / proc?dures / playbooks / REX incidents
Objectif	Transformer les alertes techniques en actions op?rationnelles compr?hensibles et reproductibles
Lien avec le SOC	Qualification, escalade, documentation, reprise et am?lioration continue
Contribution au rendu groupe	Section playbooks, proc?dures d?exploitation, recette et retour d?exp?rience

1. Positionnement du rôle

Mahamadou DIACOUMBA intervient sur la partie exploitation SOC. Son rôle est de faire le lien entre les événements techniques générés par Wazuh, pfSense, les endpoints et les logs applicatifs Daylight, et les actions concrètes que le SOC doit mener. Dans un projet de SOC externalisé, une alerte seule n'a pas de valeur si elle n'est pas qualifiée, documentée et traitée selon une procédure claire.

Son premier rôle consiste à compléter les travaux d'architecture et de SIEM. Yvan FOCSA structure les zones, les flux et la journalisation firewall. Youssef GUERNIOU rend les événements visibles dans Wazuh grâce à la collecte, aux règles, aux dashboards et au RBAC. Mahamadou prépare la réponse opérationnelle : que faire lorsqu'une alerte apparaît, qui prévenir, quelles vérifications mener, quelles preuves conserver et comment capitaliser dans un retour d'expérience.

2. Responsabilités principales

Responsabilité	Description concrète	Valeur pour Daylight
Playbooks	Définir les étapes de réponse pour les alertes importantes : brute force, accès patient, privilèges, blocage firewall.	Le client sait quoi faire, dans quel ordre, et avec quel niveau d'escalade.
Procédures	Formaliser les contrôles de reprise du lab, la vérification des services, la remontée des logs et les tests de recette.	La solution reste exploitable après redémarrage ou reprise par un autre opérateur.
Qualification	Lire l'alerte, identifier la source, comprendre le contexte et distinguer faux positif, incident réel ou action légitime.	Les alertes deviennent des décisions SOC, pas seulement des lignes dans un dashboard.
REX incident	Documenter ce qui s'est passé, ce qui a été détecté, ce qui a manqué et ce qui doit être amélioré.	Le SOC progresse au fil des incidents et réduit les angles morts.

3. Playbooks de réponse

Les playbooks ci-dessous constituent la base opérationnelle du SOC Cyber Trust. Ils sont volontairement simples et applicables au démonstrateur, mais ils préparent aussi une exploitation réelle chez Daylight.

Playbook	Déclencheur	Actions de traitement
Force brute SSH	Alerte Wazuh 5712 ou multiples checks sur serveur-01	Identifier IP source, compte ciblé, fréquence des essais, vérifier succès de connexion, bloquer si nécessaire, escalader si compte sensible.
Accès anormal dossier patient	Règle Daylight 100120	Identifier utilisateur, patient, horaire, justification métier, vérifier réputation, prévenir référent Daylight si accès non justifié.
Modification groupe privilège	Règle Daylight 100130	Comparer à une demande valide, identifier l'auteur, vérifier contexte horaire, suspendre ou révoquer si modification non légitime.
Usage USB	Règle Daylight 100140	Identifier poste, utilisateur, heure, vérifier politique interne, demander justification, contrôler présence d'autres signaux endpoint.
Blocage pfSense vers MGMT/SOC	Règle 110020 ou logs firewall	Identifier source, destination, réputation, poste concerné, vérifier si comportement utilisateur ou tentative de mouvement latéral.

4. Procédures d'exploitation et de recette

La procédure d'exploitation garantit que le démonstrateur peut être relancé et testé sans dépendre d'une seule personne. Elle est importante pour la soutenance, mais aussi pour montrer au client qu'un SOC externalisé doit être maintenable.

Contrôle	Procédure attendue	Résultat attendu
Wazuh Dashboard	Accéder à l'interface web, vérifier l'authentification et	Interface SOC accessible.

	la disponibilité?	
Agents Wazuh	Vérifier poste-01 et serveur-01 dans la liste des agents.	Sources endpoint et serveur actives.
Serveur Linux	Relancer SSH, rsyslog et l'agent Wazuh si le lab a t'arrê?	Logs auth.log et événements SSH collectés.
pfSense	Vérifier dashboard, règles LAN/WAN, logs firewall et remote syslog.	Blocages visibles côté firewall et côté Wazuh.
Scénarios de test	Déclencher un événement contr? : force brute SSH, log Daylight, blocage pfSense.	Alerte visible, qualifiable et documentable.

5. Qualification des alertes

La qualification est l'étape qui vise à traiter toutes les alertes au même niveau. Mahamadou doit montrer que le SOC applique une lecture progressive : source, contexte métier, réputation, impact potentiel et nécessité d'escalade.

Critère	Question à poser	Exemple
Source	L'alerte vient-elle d'un poste, d'un serveur, du firewall ou de l'application métier ?	pfSense pour un mouvement vers MGMT, serveur-01 pour SSH.
Contexte métier	L'action est-elle normale pour l'utilisateur et l'heure ?	Accès dossier patient hors contexte de rendez-vous.
Réputation	L'événement est-il isolé ou répété ?	Plusieurs checks SSH sur une période courte.
Impact	La donnée ou la zone cible est-elle sensible ?	Dossiers patients, administration, SOC, privilèges.
Escalade	Faut-il prévenir le client ou isoler un poste ?	Modification groupe privilège non validée.

6. REX incidents

Le retour d'expérience permet de transformer un scénario de test ou un incident réel en amélioration. Après chaque alerte importante, l'équipe doit conserver une trace courte : événement observé, action menée, résultat, limite constatée et amélioration proposée.

Élément du REX	Contenu attendu
Résumé	Décrire l'incident en une phrase compréhensible par le client.
Chronologie	Lister l'heure de détection, de qualification, d'escalade et de clôture.
Preuves	Captures Wazuh, logs pfSense, source concernée, règle déclenchée.
Décision	Faux positif, incident confirmé, surveillance renforcée ou escalade.
Amélioration	Ajuster une règle, enrichir un dashboard, compléter un playbook ou durcir un flux.

7. Ce que Mahamadou doit défendre ? Oral

Oral, Mahamadou peut présenter sa partie de manière simple et professionnelle :

- Le SOC ne sert pas seulement à afficher des alertes ; il doit les transformer en actions.
- Les playbooks donnent une méthode de traitement reproductible pour les scénarios importants.
- Les procédures permettent de vérifier que le lab fonctionne et que les événements remontent bien.
- Le REX permet d'améliorer la solution après chaque test ou incident.
- Sa partie relie les preuves techniques à une exploitation réelle chez Daylight.

8. Conclusion

La contribution de Mahamadou DIACOUMBA donne au projet une dimension opérationnelle. Sans procédures ni playbooks, le démonstrateur resterait un ensemble d'outils et de captures. Grâce à ce projet, Cyber Trust peut expliquer à Daylight comment une alerte est reçue, qualifiée, traitée, documentée et utilisée pour améliorer le SOC.